



No Certificate Revocation

Timothy Loudon, Melvin Viado, Daniel Lindo



What is it?

Certificate revocation is used to revoke access to resources on a network before the natural expiration time of the certificate. This is used to mitigate and prevent threats such as:

- Compromised private keys
- Man-in-the-Middle attacks
- Fraudulent certificates being used by threat actors

The ability to revoke certificates is very important for the safety of a network and to ensure that everyone using the network is who they say they are.



Risks

- Systems cannot detect when a certificate is no longer valid
- Networks are vulnerable to prolonged attacks
- Attackers can impersonate until the certificate expires
- Clients trusting outdated or expired certificates
- No certificate revocation gives attackers time before natural expiry

Real-life example

Heartbleed bug in OpenSSL, led to attackers gaining access to thousands of private keys.

The fallout of this vulnerability included leaked usernames and passwords, eavesdropping on communications, and session cookies





Reasons for “no certificate revocation” events

- **No Certificate Revocation Lists (CRL) or Online Certificate Status Protocol (OCSP)**
- Firewall restrictions, network issues, misconfigured browsers
- If a CRL is outdated or expired, system can accidentally accept an outdated certificate
- Being unable to verify digital certificates can lead to revenue losses for organizations
- OCSP Responders can be slow or down (from a single point of failure) delaying certificate validity.



Solutions

- Using a tool to manage certificates along with proper permissions and controls put in place
- It is necessary that revocation checks are implemented to keep track of stolen certificates
- Revocation checks are also necessary to ensure that clients are not making use of invalid certificates or accessing resources that have not been validated
- Compromised certificates should be invalidated immediately to reduce the attack surface, and ensure that users are not at risk
- Invalidating old certificates is also necessary to prevent unauthorized access by attackers
- Logs should also be kept to manage certificates that have been issued



Mitigations

- A major way to overcome no certificate revocation is to make use of certificates that expire within a short period of time, say a few months rather than years.
- Systems should also be automated so that as soon as a certificate is no longer valid, it is then replaced with a new cert
- Issuing certificates for critical services should be short lived and rotated accordingly
- The best mitigation however is early detection. If a certificate is found to be compromised, it should be removed as soon as possible.



Resources

- <https://www.encryptionconsulting.com/education-center/what-is-certificate-revocation-and-how-is-it-used/>
- knowledge.digicert.com/general-information/ocsp-crl-revoked-ssl-certificates
- <https://www.encryptionconsulting.com/the-hidden-risks-of-expired-certificate-revocation-lists-crl/>
- [Certificate Without Revocation Control – Help Center](#)
- <https://support.securityscorecard.com/hc/en-us/articles/35061464194843-Certificate-Without-Revocation-Control>
- <https://www.heartbleed.com>